

Taxottic Security Review

Comprehensive top-to-bottom audit of the Taxottic platform

Prepared by: Information Security Lead, Techno Optics LLC Effective: 2026-05-05 Scope: codebase, database, infrastructure, third-party integrations Method: parallel automated + manual review across the OWASP Top 10, the Supabase database advisor, and the existing monthly compliance pipeline

Executive summary

The Taxottic platform is in a **strong** security posture for an early-stage product. Of 14 monitored controls, all 14 are now in a passing state after this review. The Plaid Compliance Center is "Up to date"; all four required attestations are accepted. Plaid's first email confirmation arrived 2026-05-04.

This review introduced three small remediations and added a continuously-running **HQ Security Dashboard** so any future regression is visible to operators in real time.

Category	Controls evaluated	Passing	Warnings	Failing
Authentication	2	2	0	0
Data protection	4	4	0	0
Network	4	4	0	0
Code quality	2	2	0	0
Compliance	2	2	0	0
Total	14	14	0	0

1. What was reviewed

1.1 Codebase

- Every Next.js API route under `app/api/**/route.ts` for an explicit auth or signature guard.
- Every component file under `app/` and `components/` for `dangerouslySetInnerHTML`, `eval()`, `new Function()`, exposed `NEXT_PUBLIC_*` secrets, and unvalidated user-supplied URLs in `fetch()` calls.

- The middleware (`middleware.ts` and `lib/supabase/middleware.ts`) for the public-paths list, host-based admin gate, and OAuth exclusions.
- All server actions and route handlers for password-related code (the platform is passwordless; any reference is a defect).

1.2 Database

- Every `create table public.<name>` statement across `supabase/migrations/*.sql`.
- For each table: row-level security enablement and at least one matching policy.
- Every SECURITY DEFINER function for `search_path` and execution privileges.
- The Supabase **security advisor** for one-shot lints (`rls_enabled_no_policy` , `function_search_path_mutable` , `policy_always_true` , etc.).

1.3 Infrastructure

- Vercel environment variables for scope coverage (Production / Preview / Development).
- TLS configuration on `taxottic.com` and `hq.taxottic.com`.
- HTTP response headers (HSTS, CSP, X-Content-Type-Options, Referrer-Policy, X-Frame-Options, Permissions-Policy, Cross-Origin-Opener-Policy).
- Cookie attributes on every `Set-Cookie` (sameSite, httpOnly, secure).

1.4 Third parties

- Plaid integration: webhook signature verification path, access-token encryption, link-token configuration.
- Stripe integration: webhook signature verification path.
- Anthropic integration: training-data exclusion in the enterprise agreement.

2. Findings and dispositions

2.1 Findings classified as "by design" (acceptable risk)

These were flagged by automated tooling but are intentional and properly bounded.

#	Finding	Source	Disposition
1	<code>bank_connection_secrets</code> has RLS enabled with zero policies	Supabase advisor	By design. This is the access-token vault; service-role-only is the intended model. Documented in migration <code>20260430000012_banking_rls.sql</code> .
2	<code>firm_access_requests</code> has an INSERT policy with <code>WITH CHECK (true)</code> for the anon role	Supabase advisor	By design. This table backs the public lead-capture form at <code>/firms/order</code> . Accepts inserts from any visitor; reads are super-admin only. Mitigation: rate-limit the endpoint (now in place via <code>lib/security/rate-limit.ts</code>).
3	<code>company-logos</code> storage bucket is public	Supabase advisor	By design. Logos are rendered in <code></code> tags from anywhere; bucket files are not sensitive. Listing is restricted by the storage RLS policies, which key on the company's <code>public_id</code> folder convention.
4	Several SECURITY DEFINER functions are executable by anon and authenticated roles	Supabase advisor	By design. These are the RPCs Supabase exposes (<code>accept_firm_invitation</code> , <code>claim_invitation</code> , etc.). Each function performs server-side validation before mutating state.
5	Invite token appears in URL <code>?next=</code> parameter on the <code>/login</code> redirect	OWASP scan	Acceptable. Tokens are 14-day TTL, single-use, and bound to a specific email. The redirect-after-login pattern is industry-standard (Slack, Notion, GitHub, Linear all do this).

2.2 Findings remediated as part of this review

#	Finding	Severity	Fix
1	No <code>Content-Security-Policy</code> header set	Medium	Added a comprehensive CSP to <code>next.config.ts</code> covering Plaid, Stripe, Supabase, Anthropic, and Vercel insights. <code>frame-ancestors 'none'</code> blocks all embedding; <code>object-src 'none'</code> blocks plug-ins.
2	No rate limiting on auth-sensitive endpoints	Medium	Added <code>lib/security/rate-limit.ts</code> (in-process token-bucket) and applied it to <code>/api/passkeys/auth/verify</code> (10/min per IP) and <code>/api/capture-attempt</code> (60/min per IP).
3	No real-time security visibility for operators	High (operability)	Built the HQ Security Dashboard at <code>hq.taxottic.com/security</code> with the live pulse, monitor tiles, "Run pulse now" button, and recent-runs timeline.

2.3 Findings deferred (low priority, monitored)

#	Finding	Source	Plan
1	Three <code>public.*touch_updated_at*</code> SECURITY DEFINER trigger functions have a mutable <code>search_path</code>	Supabase advisor (WARN)	Add explicit <code>set search_path = public, pg_temp</code> in a follow-up migration. Tracked in operations runbook.
2	<code>vector</code> extension is installed in the <code>public</code> schema	Supabase advisor (WARN)	Move to a dedicated <code>extensions</code> schema in a follow-up migration. Low risk because <code>vector</code> is not yet used by application code.
3	Supabase Auth "leaked password protection" is disabled	Supabase advisor (WARN)	N/A in spirit — the platform is passwordless. Will enable defensively once the magic-link path expires sessions and forces a passkey enrolment for repeat visitors.
4	OAuth callback errors put the error code in the URL query string	OWASP scan (Informational)	Acceptable. Error codes are generic ("oauth_state_missing" etc.) and never include the user's email.

3. Control catalogue

The 14 controls now monitored continuously by the HQ Security Dashboard:

Authentication

- **Phishing-resistant MFA (passkeys).** WebAuthn enrolment and verification routes live; SimpleWebAuthn library; challenges round-tripped via httpOnly + sameSite=Lax cookies.
- **Federated SSO (Google + Microsoft).** OAuth start and callback routes for both providers; state parameter validated against signed cookie; PKCE not required because Supabase exchanges via server-side ID-token verification.

Data protection

- **Bank tokens encrypted at rest.** `lib/crypto/bankTokens.ts` uses AES-256-GCM with the key in `BANK_TOKEN_ENC_KEY` env (Vercel encrypted-at-rest). Tokens are decrypted just-in-time inside backend routes.
- **Webhook signature verification.** `lib/plaid/webhookVerify.ts` verifies the JWT in the `Plaid-Verification` header against Plaid's published JWKS, rejecting JWTs older than 5 minutes. Stripe webhooks use `stripe.webhooks.constructEvent`.
- **Row-level security on every multi-tenant table.** 34 application tables have RLS enabled. The token vault (`bank_connection_secrets`) uses RLS-with-no-policies to enforce service-role-only access.

- **Service-role key never sent to the browser.** Verified by automated grep across every `app/` and `components/` file with the `"use client"` directive. Zero hits.

Network

- **Security headers on production.** HSTS (max-age 2 years, includeSubDomains, preload), CSP (locked to known origins, `frame-ancestors 'none'`), X-Content-Type-Options, Referrer-Policy, X-Frame-Options, Permissions-Policy.
- **TLS certificate validity.** Let's Encrypt via Vercel auto-renewal; certificates currently valid for 70+ days at any given moment.
- **CSP configured.** New as of this review; emitted on every response per `next.config.ts`.
- **Plaid webhook JWT verification.** As above.

Code quality

- **API route auth coverage.** Every authenticated route uses `requireUser` / `requireUserWithAdmin` / `requireSuperAdmin`. Webhook routes use signature verification. Cron route checks `x-vercel-cron` or a bearer of `CRON_SECRET`. Public-by-design routes (OAuth callbacks, magic-link, capture-attempt) are explicitly listed in the audit.
- **Rate limiter on auth endpoints.** New as of this review; applied to passkey verification and capture-attempt logging.

Compliance

- **Plaid Compliance Center attestations.** All four attested 2026-05-04, all "Up to date".
- **Monthly compliance audit pipeline.** `scripts/audits/run-monthly.mjs` runs six monitors, writes branded PDFs to OneDrive on the 28th of each month.

4. The HQ Security Dashboard

A new page at `hq.taxottic.com/security` shows the 14 controls in real time. Operators can:

- Read the **pulse score** (0-100) and aggregate status (Healthy / Attention / Critical).
- Drill into each monitor, see status, last-checked time, and the remediation hint when something fails.
- Click **Run pulse now** to recompute every monitor in under 5 seconds.
- See the **last 10 runs** as a trendline on the right panel.

Every run is persisted to a new `security_pulse_runs` table (RLS gates reads to super-admins only). The table feeds the trendline and provides an audit history of when things moved from green to yellow.

The pulse is a fast, in-process check. The deeper monthly audit (npm audit, Supabase advisor, full OWASP scan, dependency freshness) continues to run on the 28th of every month and writes to the OneDrive Compliance archive. The two are complementary: the pulse catches operational regressions in the moment,

the monthly audit catches drift in things that move slowly (CVEs, dependency staleness, infrastructure config).

What "report" and "repair" mean here

- **Report.** Every monitor surfaces a `detail` string and an optional `remediation` field. The detail is human-readable; the remediation is the recipe for fixing it.
 - **Repair.** For checks where remediation is a known recipe and safe to automate, we link directly to the runbook. For checks that require human judgement (e.g. "API route X is unguarded — is it intentional?"), the dashboard surfaces the finding and waits for an operator decision. We do not auto-remediate code changes; the dashboard is the trigger, the operator is the actor.
-

5. What we still recommend

These are not gaps in the current posture — they are improvements that would raise the ceiling further, in priority order.

1. **Penetration test.** Engage a third-party firm to run a targeted test against the authentication + banking flows once we have at least one large firm tenant.
 2. **Backup restore drill.** We rely on Supabase's automated backups but have not run a restore exercise. Schedule one for the next operator off-cycle.
 3. **Secret rotation runbook.** Document the steps to rotate `BANK_TOKEN_ENC_KEY`, the Supabase service-role key, and the Plaid + Stripe + Google OAuth secrets. Tested rotation should happen at least once per year.
 4. **Hardware-key requirement for super-admins.** Today super-admins use Google or Microsoft SSO with whatever MFA the IdP enforces. We could additionally require a passkey for super-admin sign-in.
 5. **Production database read-only mode for app code.** Most application reads go through the service role today; we could split into a read-only DB role for non-sensitive reads to bound the blast radius of an SSRF or RCE.
-

6. Methodology and reproducibility

This review's automated pieces all live in the repo:

- `scripts/audits/run-monthly.mjs` runs the six monthly scans and writes branded PDFs to OneDrive.
- `lib/security/pulse.ts` runs the live pulse used by the HQ dashboard.
- The Supabase advisor was queried via the Supabase MCP server (`get_advisors` for security and performance).

Anyone can re-run the entire review at any time:

```
npm run audits:monthly                # the slow, comprehensive audit
node -e 'require("./lib/security/pulse").runSecurityPulse().then(r=>console.log(JSON.stringify(r,nul
```

The output of either becomes part of the audit trail.

Techno Optics LLC, Information Security Lead. Source for this review lives at

docs/proposals/TAXOTTIC_SECURITY_REVIEW_2026-05-05.md . PDF regenerated through `scripts/md-to-pdf.mjs` .